

Governed Autonomy for Distributed Agentic Edge AI: Identity, Delegation, Zero Trust, Continuous GRC, and Formal Security Invariants

Aridio Silva
@aridiosilva
Independent Researcher
<https://github.com/aridiosilva/SGAEIA>

September 2026

Abstract

Distributed agentic AI creates authority-bearing non-human actors that can plan, invoke tools, delegate, use persistent memory, and operate under partial connectivity. This paper formalizes SGAEIA’s governed-autonomy security model: workload identity, capability-based authorization, bounded delegation, criticality/autonomy classes, Agent Trust Zones, risk-adaptive authority, policy decision/enforcement separation, revocation, evidence-as-code, and fail-secure edge operation. The model is an executable reference specification, not a production certification.

Project: SGAEIA — Secure Governed Autonomous Edge Intelligence Architecture.

1 Motivation

Edge intelligence places AI close to data and physical processes [2]; agentic systems add tool use, memory, planning, and collaboration [15]. Security must therefore govern the authority-bearing agent, not only the model endpoint. Emerging agentic threat research highlights tool misuse, memory poisoning, autonomy, and coordination risks [16, 10, 9].

2 Security Objective

The objective is

$$UsefulAutonomy \wedge BoundedAuthority \wedge ExplicitTrust \wedge Revocability \wedge Auditability.$$

No model-generated semantic judgment alone is sufficient to authorize a critical action.

3 Identity and Capability

Every governed agent receives a non-human identity bound to its workload/execution context. SPIFFE demonstrates a standard model for verifiable workload identity [11]. Identity is necessary but insufficient: authorization also depends on capability, policy, risk, context, and delegation.

4 Delegation

For parent p and child c ,

$$C(c) \subseteq C_{delegated}(p), \quad depth(c) \leq MaxDepth.$$

Delegation also carries expiry, resource, purpose, and context constraints. Authority cannot be created merely by an agent claiming it.

5 Criticality, Autonomy, and Trust Zones

Criticality $L0 \dots L4$ and autonomy $A0 \dots A5$ are independent dimensions. The reference invariant is $L4 \wedge A5 \Rightarrow DENY$. Effective autonomy is the minimum permitted by configured, risk, context, trust, and policy bounds. ATZ-0 through ATZ-5 classify control requirements without granting transitive trust.

6 Authorization and Zero Trust

For agent a , request r , object o , context c , and time t :

$$Authorize = I(a) \wedge Cap(a, o) \wedge P(a, r, o, c) \wedge R(a, r, o, c, t) < \theta \wedge T(a) > \tau.$$

The PDP/PEP is external to the LLM. NIST Zero Trust supports identity-centric, explicit policy enforcement rather than network-location trust [4, 5].

7 Fail-Secure Edge Operation

Edge disconnection must not increase authority:

$$OfflineMode \Rightarrow Authority_{offline} \leq Authority_{online}.$$

Critical operations may require cached bounded policy, short-lived identity, human approval, independent safety interlocks, or denial.

8 Revocation

Revocation is temporal:

$$RevocationRequested(t_0) \Rightarrow AuthorityUnavailable(t \leq t_0 + \Delta_{max}).$$

The bound is deployment-specific and must be measured across identity, policy, mesh, caches, tools, and edge nodes.

9 Continuous GRC

NIST AI RMF and its GenAI Profile motivate lifecycle governance [6, 7]. SGAEIA turns the governance chain into runtime evidence:

$$Requirement \rightarrow Risk \rightarrow Control \rightarrow Policy \rightarrow Enforcement \rightarrow Evidence.$$

10 Threat-to-Control Mapping

Threat	Representative controls
Agent impersonation	workload identity, attestation, short-lived credentials, revocation
Delegation escalation	subset/depth/expiry/context checks
Prompt/tool injection	untrusted-input zone, tool mediation, capability checks
Memory/RAG poisoning	provenance, source policy, isolation, retrieval authorization
Autonomous lateral movement	mesh identity, egress control, least privilege
Unsafe actuation	criticality limits, approval, independent safety barrier
Evidence suppression	buffering/sealing/correlation/monitoring

11 Security Invariants

$$\begin{aligned}
&AgentWithoutIdentity \Rightarrow DENY \\
&RevokedAgent \Rightarrow DENY \\
&DelegationDepth > MaxDepth \Rightarrow DENY \\
&ChildCapabilities \not\subseteq ParentDelegatedCapabilities \Rightarrow DENY \\
&AttestationFailed \wedge CriticalAgent \Rightarrow STOP \vee QUARANTINE.
\end{aligned}$$

12 Formalization and Limits

TLA+ and Alloy artifacts are included as specifications; selected equivalent finite-state properties are tested in Python. No claim is made that TLA+/Alloy model checking has been executed. Risk scoring, safety constraints, and revocation bounds require domain-specific and live validation.

13 Conclusion

Agentic Edge AI requires security to govern authority rather than connectivity alone. SGAEIA makes identity, capability, delegation, risk, enforcement, evidence, and revocation explicit and testable.

Availability

Open reference implementation and specifications: <https://github.com/aridiosilva/SGAEIA>.

References

- [1] W. Shi et al., “Edge Computing: Vision and Challenges,” IEEE Internet of Things Journal, 3(5), 637–646, 2016. doi:10.1109/JIOT.2016.2579198.
- [2] Z. Zhou et al., “Edge Intelligence: Paving the Last Mile of Artificial Intelligence With Edge Computing,” Proceedings of the IEEE, 107(8), 1738–1762, 2019. doi:10.1109/JPROC.2019.2918951.

- [3] E. Li, Z. Zhou, X. Chen, “Edge Intelligence: On-Demand Deep Learning Model Co-Inference with Device-Edge Synergy,” MECOMM, 2018. doi:10.1145/3229556.3229562.
- [4] NIST, Zero Trust Architecture, SP 800-207, 2020. doi:10.6028/NIST.SP.800-207.
- [5] NIST, A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments, SP 800-207A, 2023. doi:10.6028/NIST.SP.800-207A.
- [6] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), AI 100-1, 2023. doi:10.6028/NIST.AI.100-1.
- [7] C. Autio et al., Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024. doi:10.6028/NIST.AI.600-1.
- [8] NIST, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models, SP 800-218A, 2024.
- [9] MITRE, ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems, <https://atlas.mitre.org/>, accessed Sep. 2026.
- [10] OWASP GenAI Security Project, Agentic Security Initiative and Agent Control Standard, <https://genai.owasp.org/>, accessed Sep. 2026.
- [11] SPIFFE Project, The SPIFFE Standard, <https://spiffe.io/docs/latest/spiffe-specs/>, accessed Sep. 2026.
- [12] ETSI, Multi-access Edge Computing (MEC), <https://www.etsi.org/technical-groups/mec/>, accessed Sep. 2026.
- [13] OpenAPI Initiative, OpenAPI Specification 3.2.0, 2025.
- [14] AsyncAPI Initiative, AsyncAPI Specification 3.1.0, 2026.
- [15] K.-T. Tran et al., “Multi-Agent Collaboration Mechanisms: A Survey of LLMs,” arXiv:2501.06322, 2025.
- [16] S. Datta et al., “Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges,” arXiv:2510.23883, 2025.